MIGRATION HAND-OFF

SORMAS on Vaadin 25: hand-off document

What changed, how to deploy and run the migrated application, and what to check before go-live

FUNCTIONAL PARITY (MILESTONE M2) PASSED; CUSTOMER ACCEPTANCE (MILESTONE M3) NOT YET REACHED

Version	2 (for the customer walkthrough)
Date	2026-11-13
Status	Functional parity (milestone M2) passed; customer acceptance (milestone M3) not yet reached
Prepared for	Operators, administrators, developers and product owners of SORMAS
Prepared by	Migration team

Figures are as of 2026-11-13 and trace to the migration's records. This version follows the change review and the fixes it asked for. Points still open are marked "TO CONFIRM" and listed in Appendix A.

Contents

Executive summary 3

How to read this document 3

1 What changed for users 5

1.1 Material functional change: rich text formatting 5

1.2 Everyone: look and common controls 5

1.3 Links, addresses and logging in 6

1.4 Forms and data entry 6

1.5 Lists, exports and dashboards 7

1.6 Who notices what, in short 8

2 What changed for operators and administrators 9

2.1 Platform 9

2.2 Server libraries and configuration in the application 9

2.3 Database queries 10

2.4 Security, login and REST 10

2.5 Single sign-on with Keycloak 10

2.6 Outside services and network 11

2.7 Monitoring and HTTP behaviour 11

2.8 Performance and capacity 11

3 Environment and deployment 13

3.1 Requirements 13

3.2 Commercial components and the licence key 13

3.3 Setting up a Payara 7 server 13

3.4 Upgrading an existing installation 14

3.5 Continuous integration 14

3.6 Test environment scripts 15

4 Database migration scripts and pre-go-live checks 16

4.1 No migration script 16

4.2 Check 1: rich text that would lose formatting 16

4.3 Check 2: records with an empty link 17

5 Licences, third-party code and library advisories 18

5.1 Licence of the delivered application 18

5.2 Third-party code in the migrated code 18

5.3 Libraries kept at their old versions, and their advisories 18

5.4 Proposed upgrades: a follow-up offer 19

6 **Known pre-existing issues** 20
6.1 To act on 20
6.2 Errors users may see 20
6.3 Display and wording 21
6.4 Operations and tests 21
7 **Behaviour changes and their decisions** 22
7.1 Decided at planning and during the migration 22
7.2 Change review (answered 2026-11-13) 23
7.3 Improvements beyond parity 23
7.4 To be confirmed 24
8 **How to run and test** 25
8.1 Build 25
8.2 Start a test copy 25
8.3 Unit tests 25
8.4 End-to-end workflow tests 25
9 **Follow-up candidates** 27
10 **Side-by-side recordings** 28
A **Open points** 29

Executive summary

Outcome. SORMAS v1.104.0 has been moved from Vaadin 8 on Java 11 / Payara 5 to Vaadin 25 on Java 21 / Payara 7 (Jakarta EE 11) with Hibernate 7.4, keeping what the application does. The migrated application was compared with the old one, step by step, on 62 user workflows in two configurations: 61 behave the same and 1 differs in an agreed way (the link format in task notification e-mails). The data shown to each test user is the same as in the old application (1,896 comparisons, 0 differences). The internal reviewer, acting for the customer, passed **functional parity (milestone M2)** on 2026-11-13 after walking through every workflow old against new. The database schema is unchanged: no migration script is needed. All 2,232 unit tests pass and none was switched off. All 62 workflows also run as automated browser tests (288 steps) in CI.

What changed. The user interface is rebuilt on Vaadin 25. It keeps the SORMAS look and layout but is not pixel-identical (section 1). Old `#!` links in bookmarks and earlier e-mails open the start page. The server platform, its libraries and some server settings change (sections 2 and 3). One change is a **material functional change**: rich text loses formatting the new editor does not support when it is edited and saved (section 1.1). Three Vaadin commercial components are used (Rich Text Editor, Charts, Map): building the application needs a Vaadin subscription key (section 5).

Risks to manage before go-live.

1. Rich text formatting loss on edit: run the count query in section 4.2 on your data.
2. Six database columns that may be empty would hide their records: run the count query in section 4.3; expected 0.
3. Every Payara 7 server needs one transport setting, or large pages stay blank. The updated setup script sets it (section 3.3).
4. Third-party libraries kept at their old versions carry 128 known security advisories (8 critical, 49 high), the same as in the old application; none is new. An upgrade plan is in section 5.4.
5. Keycloak single sign-on works with Keycloak 21.1.2 and a new password hash provider jar from this release; test it with your own Keycloak (section 2.5).
6. A pre-existing defect loses a date-and-time value when the date part is mistyped (Ref. B065); it is to be fixed right after the migration (section 6).

Decisions needed.

- Customer acceptance (milestone M3), after this walkthrough.
- Two improvements beyond parity in typed two-digit years are waiting for confirmation (section 7.4).
- Whether to order the library upgrades (section 5.4) and the other follow-ups (section 9).
- Where the migrated code ends up: merged into `main`, replacing it, or handed over as the `mig-dev` branch next to the old version on `main`.

How to read this document

Section 1 is for everyone who uses SORMAS. Sections 2 to 5 are for operators, administrators and whoever handles licences; section 8 is for developers. Section 6 lists problems that the old application already had. They are still there, because the migration copies the old behaviour, defects included, unless a decision says otherwise. Section 7 lists the decisions behind the changes.

A separate document, the *final migration report*, describes how the migration was done and verified, with the full verification results and the timeline.

Terms used here:

- **Old application:** SORMAS v1.104.0 as imported (branch `main`). **New application:** the migrated code (branch `mig-dev`, with the hand-off work on `stage/3-handoff`).
- **Milestones** are sign-offs by the internal reviewer, who acted as the customer's representative: M0 the plan, M1 the application runs, **M2 functional parity** (every workflow does what it did), **M3 customer acceptance** (the last one, after this hand-off).
- **C1** and **C2:** the two test configurations. C1 is the default country with English. C2 is Germany (German) with campaigns, adverse events following immunization (AEFI), environments, surveys, self reports, the GDPR notice

and travel entries switched on.

- **Workflow:** one user task from the migration's catalogue of 62 (for example "create a new case for a new person"). Each was recorded on the old application and replayed on the new one.
- **Ref. B0nn:** the migration's reference number for a pre-existing problem (section 6). **CRnn:** an item of the change review, the list of changes the internal reviewer answered on 2026-11-13 (section 7.2). Quote either when you ask the migration team about it.

1 What changed for users

This section lists the changes users can notice. It is written from the migration's register of material changes; changes that were later undone are left out. Where the new application deliberately behaves better than the old one, this is marked **Improvement**.

1.1 Material functional change: rich text formatting

Rich text fields (an action's description and reply, and the case definition text in disease configuration) use the Vaadin Rich Text Editor. **When such a text is edited and saved, formatting the new editor does not support is removed**: font face, size and colour set with `<font>`, tables (the text stays), horizontal rules, headings H4 to H6, images linked by address (embedded images stay), `javascript:` links, scripts and event attributes. Links get `rel="nofollow"`. Stored texts are not changed until someone edits and saves them.

This was accepted, with the condition that it is presented as a material functional change and that the affected texts are counted before go-live (CR02, 2026-11-13). Section 4.2 has the count query. If the count matters, ask for a fix.

The editor's toolbar differs from the old one: it has undo/redo, bold/italic/underline/strike, text and background colour, headings H1 to H3, sub- and superscript, lists, indent, alignment, image, link, block quote, code block and clear formatting. Lines the old editor stored as `<div>` show as paragraphs. **Improvement:** scripts in rich text are removed.

1.2 Everyone: look and common controls

- **Look.** The application keeps the SORMAS colours (primary `#005A9C`, menu `#6691C4`), the Open Sans 12 px font, upper-case captions and buttons and the left menu. Controls have the shapes of the new Vaadin theme (Lumo): radio buttons, check boxes, lists, dialogs and the calendar look different. The left menu no longer collapses on narrow screens.
- **Pop-up windows** (forms, confirmations, warnings) are Vaadin 25 dialogs. As before, they are modal and movable, cannot be resized, have a close button and close with Escape, and do not close on a click outside. The header looks different. Keyboard focus stays inside the dialog while it is open.
- **Drop-down buttons** (Export, Import, New, dashboard period, map key and layers, epi-curve grouping, e-diary options) open a pop-over below the button. It closes on a click outside or Escape.
- **Lists** keep their columns, captions, order, sorting (click, shift-click for more columns), loading 100 rows at a time while scrolling, selection modes and double-click to open. As before, only the sorted column shows a sort arrow and keeps its width. Icons in list cells (edit, view, create case) are the new theme's icons.
- **Read-only values** (for example age, "last updated", a hospital informant's locked case fields) show as plain text next to the caption, as before. Disabled fields keep a dimmed, framed look.
- **Drop-down fields (combo boxes).** A value is cleared with the × button, not by picking an empty first entry. "Inaccessible" appears as grey placeholder text. Eight drop-downs that did not accept typing now accept typing to filter.
- **Date fields.** The display format is unchanged. A typed date must match that format; the old date field also accepted some other spellings. An unreadable date blocks Save with "Date format not recognized", as before. The calendar opens from its button. It shows month and weekday names and the first day of the week in the browser's language (German browser: Monday first, German names). It has new **Today** and **Cancel** buttons, captioned in German for German and in English for every other language until they are translated.
- **Two-digit years.** Typed into a date field with its own format (form dates, task due dates, birth date filters), a two-digit year is read as the old forms read it: at most 10 years ahead and 89 years back (in 2026: 3/14/70 is 1970, 3/14/30 is 2030). Date filters without their own format read two-digit years from 80 years back to 20 years

ahead, as before. Two cases where the new application reads a year better than the old one are waiting for confirmation (section 7.4).

- **Field hints and messages.** Non-blocking hints (for example the Luxembourg national health id check, the follow-up-until hints, "admission date before symptom onset", the fever/temperature hint) appear as grey text under the field. In the old application they appeared on hover over an indicator. Error messages appear in red under the field. None of them blocks saving, as before.
- **Tooltips with formatted text** (automatic deletion date, "most relevant date" in list filters, previous case of a reinfection) show the same text with simpler formatting.
- **Notifications** look and behave as before: caption and text on one bar with a round close (×) icon; a click on it, or on the notification, closes it. Information notices close at the next user action, warnings 1.5 s after it, errors stay until clicked. Small look differences remain (section 9).
- **Refused Save.** The "Please check the input data" notification lists the missing fields in the order of the form. **Improvement:** the old application's order changed every time the form was opened.
- **Leaving a page with unsaved changes.** Moving inside the application still shows the "Unsaved changes" prompt. Leaving through the browser (Back to a page loaded on its own, a typed address, reload, closing the tab) shows the browser's own "Leave site?" dialog. A value still being typed counts as unchanged, and logout discards without asking, as before. **Improvement:** the old application discarded changes without a warning on reload and when the tab was closed (decided 2026-11-13).

1.3 Links, addresses and logging in

- **Old links.** Addresses in the old format (`<server>/sormas-ui/#!cases/data/<id>`), in bookmarks and earlier notification e-mails, open the start page, not the record. New addresses are paths: `<server>/sormas-ui/cases/data/<id>` . Task notification e-mails sent by the new application use the new format.
- **Login page address.** When a page that needs a login is opened without one, the login page address keeps the requested page as `login?target=<page>` (old: `login#!<page>`). After login the user lands on that page. The target must name a page of the application; anything else (`..` , a leading slash, another scheme, percent-encoding) opens the start page instead (security hardening, CR15).
- **After a logout**, a second user who logs in on the same login page lands on the first user's last page, as in the old application. The second user's own rights apply.
- **Addresses typed by hand.** A sub-page the user has no access to, or one that does not exist, shows "access denied" or "view not found". The old application silently opened the parent page instead.
- **Several tabs.** Opening the application in a new browser tab re-checks the pages the user may open, for all tabs of that login. A change of the user's rights then applies in every tab.
- **Rights changes.** A change to a user's roles applies at the user's next page change. In the old application it applied at the next login. Deactivating a logged-in user still applies at the next login.
- **A page that fails to open** shows the generic "An error has occurred" notification, as before, but the page area stays empty and the address bar shows the failed page. The old application kept showing the previous page.
- **Errors during page load.** An unexpected error from the server now always shows its notification. The old application sometimes showed nothing.
- **Menu.** A page opened directly by its address (for example a person page) highlights no menu entry.

1.4 Forms and data entry

- **Tables inside forms** (person addresses and contact details, previous hospitalisations, exposures, activities as case, vaccinations, AEFI vaccinations) use the new list component. Columns, the edit/view button, double-click to open and "new entry" are kept. Column widths follow the content.

- **Uploads.** CSV imports and document-template uploads use a new upload button that shows the file name and progress below it. Document uploads with several files save the files after all have uploaded, not one by one; the size limit, warnings and "file exists" prompts are unchanged.
- **Address map** in location forms (eye button next to the coordinates, only when geocoding is configured): the map opens in a pop-over below the button and closes on a click outside or Escape. Before, it closed when the mouse left it.
- **Custom date-and-time fields** (customizable fields of type "date and time", also their default value in configuration) show the date in the user's format and the time in the browser's format.
- **Statistics filters** (attribute values, jurisdiction, place of residence): values are picked in one drop-down and shown as removable chips. Picking a marked value again removes it. **Improvement:** a picked district, community or facility stays picked when the list is rebuilt. The old application could ignore it or show a district twice.
- **Campaign selector** (campaign data and statistics): "All campaigns" is chosen with the × button; it was an entry in the list.
- **Hospital informants creating a case.** Choosing a disease no longer shows "An unexpected error occurred". The rest of the disease handling now runs for them as for other users (for example influenza presets the classification to Confirmed). The preset facility is kept. **Improvement.**
- **An open form refreshed with a new copy of the same record** shows the new values.
- **Saved values that are no longer active** (archived region, district, facility and so on) show their name followed by "(Inactive)", as before.
- **Values the application writes into locked (read-only) fields** are refused as in the old application: the action stops and "An unexpected error occurred" is shown. **Improvement:** two-part fields (user fields, date-and-time fields) showing a new value in their locked part no longer raise this error.

1.5 Lists, exports and dashboards

- **Event directory for regional, district, community, facility and laboratory users.** Each event appears once and none is missing, and the count matches the rows. **Improvement:** the old application could list the same event several times and miss others (Ref. B064). The REST list endpoint for events pages the same way.
- **Self report basic export.** The "process" column is empty. The old application wrote internal object text into it. **Improvement.**
- **User roles export.** On the "User rights" sheet, the required rights are listed in a fixed order. **Improvement:** the old order changed with each server start.
- **Downloads** (exports, data dictionary, documents) keep their file names and types. Their internal addresses change, and the browser shows a link on hover.
- **Charts** (dashboards, statistics, campaigns, AEFI) are drawn by Vaadin Charts (Highcharts 12 inside; was Highcharts 8). Chart types, series, colours, labels, legends and export menu are kept. Fonts, tooltip and menu styling differ slightly. **Improvement:** keyboard navigation and screen-reader descriptions of charts.
- **Maps** (surveillance, contact, event, sample, AEFI and GIS dashboards, statistics map, address maps) are drawn by Vaadin Map (OpenLayers) with the same tile server, markers, clusters, polygons, clicks and full screen. Accepted differences: region and district names (and statistics values) do not show on hover; overlapping markers are not spread apart on click; markers of different kinds form separate clusters, and a cluster's number counts its markers; sample and AEFI markers are coloured squares; mouse-wheel zoom is finer (about 0.4 levels per notch); world maps open zoomed to the map's width.

1.6 Who notices what, in short

Who	Main changes
All users	New look of controls, dialogs, drop-down buttons, calendar; browser warning before leaving unsaved changes; old `#!` links open the start page
Users of rich text (actions, disease configuration)	New editor; unsupported formatting removed on save (material functional change)
Users typing dates	Strict date format; new Today/Cancel buttons; two-digit years as in the old forms
Dashboard, statistics and map users	Charts and maps redrawn; no hover names on maps
Hospital informants	No error when choosing a disease for a new case
Regional and district users	Event directory without duplicates
Administrators	Role changes apply at the next page change
Users with bookmarks or old e-mails	Old links open the start page

2 What changed for operators and administrators

2.1 Platform

Part	Old	New
Java	11	21
Application server	Payara 5.2022.5 Full (Java EE 8, `javax.*`)	Payara Server 7 Community Full 7.2026.10 (Jakarta EE 11, `jakarta.*`)
Web UI framework	Vaadin 8.14.3 with the Vaadin 7 compatibility layer and a GWT widgetset	Vaadin Flow 25.3.5, production mode, CDI integration 16.1.2
Persistence	Hibernate 5.6.15	Hibernate ORM 7.4.14
Second-level cache	Ehcache 2	Ehcache 3.12 through JCache, same effective sizes (10,000 entries, 120 s)
Database	PostgreSQL 14	PostgreSQL 14, schema unchanged
Topology	Backend EAR, REST war and UI war on one server	Unchanged

Developers and integrators: code and plugins compiled against `sormas-api` must use `jakarta.*` imports. A CDI extension registered under the old `javax` service file name is no longer loaded.

The Android app was outside the migration: it was not built or tested. It uses the shared API module, which now uses `jakarta.*` packages, so it needs its own build and test.

2.2 Server libraries and configuration in the application

- **Domain library folder.** The server libraries (`sormas-serverlibs`) change: Hibernate 7.4.14 with `hibernate-jcache` and Ehcache 3.12; `hibernate-types` removed; a `javax` XML Binding 2.3 set added for document generation (docx4j); `vaadin-themes` removed. An old domain library folder does not work with the new EAR and wars: `server-update.sh` replaces it.
- **JSON columns** are written by Hibernate's Jackson mapper (set in `persistence.xml`). The stored JSON text is byte-identical to the old application's. The application fails at start if Jackson is not visible to Hibernate in the domain library folder, rather than writing a different format.
- **Bytecode enhancement off.** Hibernate 7's runtime enhancement is switched off in `persistence.xml`, so entities behave as with Hibernate 5. This logs four `HHH90000029` warnings at start (the settings are deprecated). A future Hibernate upgrade that removes the settings must keep enhancement off in another way.
- **Cache configuration** is in `sormas-backend` `META-INF/ehcache.xml` (Ehcache 3 format). The Ehcache provider is named in `persistence.xml`, because Payara 7 also ships another JCache provider.
- **Deprecation messages.** Payara 7 logs `glassfish-web.xml` as deprecated, at SEVERE level, on every deploy of the two wars. It is harmless today; a later Payara release may drop support.
- **Redeploying by hand.** On Payara 7, `asadmin deploy --force=true` of the EAR into a running domain where it is already deployed fails. Restart the domain, then deploy. `server-update.sh` deploys differently and is not affected.

2.3 Database queries

The "changed since last shared with the reporting tool" and "last share date" filters (case and event directories) use a different subquery. The rows are the same; the query plan differs. Database administrators may see different plans for these filters.

2.4 Security, login and REST

- **Web login check moved into the application.** The UI no longer relies on the server's URL security constraint. The application checks the web-access right on every page change and sends visitors without it to the login page. Background UI requests without a session are refused. Data access stays protected by the backend's right checks, unchanged. Reason: with the old layout, Payara 7 refused logged-in users on the application's root address.
- **REST rights.** The right to use the REST API, and the extra rights of the external visits, BAG export and SORMAS-to-SORMAS endpoints, are checked by SORMAS against the user's role rights, not by the server. The answers are the same (401 / 200 / 500 "Caller not in requested role", checked against the old application). **A right removed by editing the database directly applies only after an application restart**; changes made in the application apply at once (CR13).
- **Login target.** The page named in a login link (`login?target=...`) must be a page of the application (section 1.3).
- **Unchanged weaknesses** of the old application are kept, as agreed (CR16, section 6): `/metrics` answers without a login; no Content-Security-Policy, no HSTS, and the session cookie has no `Secure` / `SameSite` flags; the REST catch-all error answer contains the exception message. Close `/metrics` on public listeners and add the headers and cookie flags in your TLS proxy.

2.5 Single sign-on with Keycloak

The Keycloak login was rebuilt for Payara 7 and **tested against a local Keycloak 21.1.2** with the repository's SORMAS realm: the redirect to Keycloak, login and return to the application, logout through Keycloak, refusal (HTTP 403) of users without the web UI right, and REST basic authentication through Keycloak. The outcomes are the same as the old application's on the same Keycloak. Keycloak setup is otherwise as before. What changed or was checked:

- **Keycloak version:** tested with Keycloak 21.1.2, the version of the application's Keycloak libraries and the old application's. The realm export (`sormas-base/setup/keycloak/SORMAS.json`) and the `sormas` theme are unchanged.
- **Password hash provider: deploy the jar from this release.** `sormas-keycloak-service-provider-<version>.jar` now hashes passwords itself (the same SHA-256 as SORMAS), runs on Keycloak's Java 17 and is a single small jar. Copy it to `/opt/keycloak/providers/` and rebuild or restart Keycloak. A provider jar built from the migrated code before this fix stops Keycloak 21 from starting, and without the provider users synced from SORMAS cannot log in.
- **Payara 7 domain:** the same settings as before (`keycloak-setup.sh` , now with `/opt/payara7`): `payara.security.openid.clientId` , `clientSecret` , `scope` , `providerURI` (`<keycloak>/keycloak/realms/SORMAS`), `payara.security.openid.provider.notify.logout=true` , `payara.security.openid.logout.redirectURI` , `sormas.rest.security.oidc.json` and `sormas.backend.security.oidc.json` . Then `authentication.provider=KEYCLOAK` in `sormas.properties` . These are MicroProfile Config properties: domain config properties (`asadmin set-config-property`) and environment variables (`PAYARA_SECURITY_OPENID_CLIENTID` , ...) both work on Payara 7; both were checked.
- **Addresses:** the login page sends the browser to a new address, `/sormas-ui/oidc-login` , which starts the Keycloak login. `/sormas-ui/Callback` and `/sormas-ui/logout` are unchanged. The `sormas-ui` client's

redirect URIs (`/sormas-ui/*`) already cover them; **a reverse proxy must pass `/sormas-ui/oidc-login`**.

- **Users:** as before, users are synced to Keycloak from SORMAS with their SORMAS password as a temporary credential; each user sets a new password at the first Keycloak login. A page address opened before the Keycloak login is not kept: the user lands on the start page, as before.
- **Check before going live** with your own Keycloak, realm and theme: login, logout, a refused user and one REST call. The opt-in test `KeycloakLoginIT` (section 8.4) does this against a local Keycloak.

Known pre-existing gaps in the Keycloak material (unchanged): the `sormas` login theme links a style sheet Keycloak 21 no longer ships (one browser console error per Keycloak page); `sormas-base/doc/keycloak.md` still names Keycloak 16.1.0 and `docs/SERVER_SETUP.md` gives `/auth` addresses Keycloak 21 does not use; `keycloak-setup.sh` does not pass the statistics client secret.

2.6 Outside services and network

- **Chart export server.** The chart menu's image and PDF downloads send the chart to Highcharts' public export server, now `export-svg.highcharts.com` (was `export.highcharts.com`). Print, CSV and XLS stay in the browser. If your firewall blocks the server, those two downloads fail; if your data must not leave your network, tell users not to use them, or remove the two menu entries in a follow-up.
- **Map tiles** come from the same tile server as before (OSM France HOT, or `map.tilersUrl`).
- **Build-time downloads** (build machines only): Node.js from nodejs.org and npm packages from registry.npmjs.org, pinned by the lock file, for the frontend build. The running application needs no Node.

2.7 Monitoring and HTTP behaviour

Request	Old	New
A UI address without a login	302 to `/sormas-ui/login`	200 (the start page, which shows the login at `/login`); `GET /sormas-ui/login` still answers 200
An address that matches no page of the user	200 (the page name was after `#!`)	404 with the not-found or access-denied page
Opening an address whose page fails	200	500 (no exception text shown)
Download addresses	Vaadin 8 connector addresses	Vaadin 25 dynamic resource addresses

Uptime checks on `/sormas-ui/login` are not affected. Proxies or filters that match download or login addresses need checking (CR37).

2.8 Performance and capacity

Logged as accepted (CR17, CR38); measure in the pilot if needed:

- **First page responses are larger**, about 4 to 12 times the old application's for the same page:

Page (national user, C1)	Old	New
Case symptoms	45 to 61 KB	556 KB
Case data	56 KB	475 KB
Case list	69 KB	286 KB

Page load times on slow connections were not measured.

- **Memory.** A short soak test (160 logins per application, 8 roles) showed no abnormal growth: the new application's heap grew less per login than the old one's. Its process memory ended 0.45 GB above its start (2.36 GB). Watch it in the pilot.
- **Sessions after logout.** Both applications keep the server session after logout until it times out (161 sessions after 161 logins). The session timeout limits it. This is old behaviour.
- **EJB pool.** The setup script sets the EJB pool to 128, as SORMAS intends, and now prints a warning if that fails (the pool then stays at Payara's default of 32). The old test environment ran with 32, because the setting failed there without notice (Ref. B001). Check the warning after setup.

3 Environment and deployment

3.1 Requirements

Item	Requirement
Server runtime	Payara Server 7 Community Full 7.2026.10 on a Java 21 JDK
Database	PostgreSQL 14 (the old application's database is used as it is). Note: PostgreSQL 14 reached end of support on 2026-11-12 (Ref. B006); an upgrade of the database server is a separate decision
Build	JDK 21, Maven 3.9, network access to Maven repositories, nodejs.org and registry.npmjs.org, and a Vaadin licence key (section 3.2)
Memory	The test copies run with `-Xmx4096m` and use about 2.4 to 3 GB of process memory each

3.2 Commercial components and the licence key

The UI uses three Vaadin commercial components: Rich Text Editor, Charts and Map (section 5.1). The production build of `sormas-ui` builds the frontend bundle and checks the licence. **Without a valid Vaadin key the build fails** ("Commercial features require a subscription").

- **Local and release builds:** the key is read from `~/.vaadin/proKey` or the environment variable `VAADIN_PRO_KEY`. In a container, pass the variable by name only (`docker run -e VAADIN_PRO_KEY ...`) or mount the key file read-only. Never write the key into an image, a repository file or a log.
- **CI builds** use Vaadin's "commercial with banner" option instead of a key. That build shows a banner and **must never be shipped or deployed**. CI keeps no build artefacts.

3.3 Setting up a Payara 7 server

The stock setup is updated: `sormas-base/setup/server-setup.sh` installs **Payara Server 7.2026.10** (Community, from Maven Central) into `/opt/payara7` and requires a Java 21 JDK, with the same prompts and steps as before. The service, start/stop, update and Keycloak scripts point to `/opt/payara7`, and `docs/SERVER_SETUP.md`, `docs/SERVER_UPDATE.md` and `docs/DEVELOPMENT_ENVIRONMENT.md` name Java 21 and Payara 7. Every domain setting of the old script works on Payara 7; none was dropped.

A fresh installation with the script was rehearsed on a Debian test server with Java 21 and PostgreSQL 14: the script and `server-update.sh` ran without error, the login page answered, eight test users logged in, and REST answered as expected. As a negative control, the new release deployed on an old Payara 5 / Java 11 domain does not start.

Domain settings the script makes (also listed in `docs/SERVER_SETUP.md`, for anyone who builds a domain without the script, for example a container image; the SORMAS Docker images, a separate project, need the same changes):

Setting	Value
Server	Payara Server 7 Community Full 7.2026.10 on Java 21
Transport write buffer	`asadmin set configs.config.server-config.network-config.transports.transport.tcp.socket-write-buffer-size=1048576`, then restart. **Required on Payara 7** (CR34). Without it Payara closes the connection on responses above the operating system's send buffer (about 680 KB on one test host): large pages (case data, symptoms, long lists) stay blank with no error shown, and the server log shows only `Connection is closed`
Class loading	system property `fish.payara.classloading.delegate=false` (as before)

Setting	Value
JVM	`-Xmx4096m`; logback configuration as before
Pools	EJB `max-pool-size` 128 (warning if it cannot be set); HTTP thread pool maximum 50; JDBC pool maximum 128
Resources	`jdbc/sormasDataPool`, `mail/MailSession` (Payara 7 uses Eclipse Angus Mail), `sormas/Properties` pointing to `sormas.properties` (the properties file itself is unchanged by the migration)
Domain library folder	the new `sormas-serverlibs` jars and the PostgreSQL driver (`server-update.sh` copies them)
Login realm	none, as before: SORMAS authenticates in the application

Side effects of the transport setting: sockets ask for a 1 MiB send buffer (capped by the kernel's `net.core.wmem_max`), and up to 1.5 MiB of direct memory per HTTP thread is used while large responses are written.

Small pre-existing gaps in the setup material (unchanged): the script's PostgreSQL version check never runs (a bash error); the Payara download is not checked against its checksum; `docs/SERVER_SETUP.md` does not list the operating system packages the scripts call (`wget`, `unzip`, `acl`, `sudo`, PostgreSQL client); the JDBC password is stored in clear in `domain.xml`, as before.

3.4 Upgrading an existing installation

Follow `docs/SERVER_UPDATE.md`, entry "Vaadin 25 migration (Payara 7, Java 21)". In short:

1. Install a Java 21 JDK.
2. Stop the old domain, **back up the database** and move the old domain away. Keep the database and `/opt/sormas`: the migration changes no database table.
3. Before go-live, run the two checks of section 4 on the database.
4. Run the new `server-setup.sh`. It installs Payara 7 next to Payara 5 and creates a new domain; answer *YES* to connecting to an existing database. A Payara 5 domain and its library folder cannot be reused.
5. Carry your settings over into the new domain's `sormas.properties` and `logback.xml`. Check that `ui.url` is still the UI's address: task e-mails build their links from it.
6. Run `server-update.sh`: it copies the new server libraries and deploys SORMAS. Check that the start page loads for a few users and that a large page (a case's symptoms) shows.
7. Remove `/opt/payara5` once the new server runs.

Rehearsed on test data: an old installation (old setup script, Payara 5, Java 11, the old application on its seeded test database with 84 cases) was upgraded this way; afterwards the login page answered, the case list and REST showed the same 84 cases. It was **not rehearsed on a copy of production data**, with customised roles, on Windows or macOS, or with Keycloak enabled **[TO CONFIRM: rehearse on a copy of production before go-live]**.

3.5 Continuous integration

CI is one GitHub Actions workflow (`.github/workflows/ci.yml`, described in `CI.md`). It runs on every push to any branch, once per commit; there is no pull request trigger. It has two jobs side by side:

- **Build and test** (about 20 to 23 minutes): `mvn clean install` with JDK 21 runs all unit tests. It fails if the Testcontainers database test did not run. Then a smoke test starts one app copy and logs in as each web test user, checks the first page and the `/about` page by its address, and checks that a user without web rights is refused.

- **End-to-end workflow tests (Playwright)** (about one hour; 55 to 65 minutes measured): builds the app without tests and runs all 62 workflow tests (section 8.4) on three app copies. The job's timeout is 150 minutes.

Both jobs build with the commercial banner, never with a key. On failure only, diagnostics are kept for 3 days. The upstream SORMAS workflows and Dependabot were removed from this repository. One backend test fails when the build runs between 00:00 and 06:00 (Ref. B059): avoid that window or re-run.

3.6 Test environment scripts

`env/` starts reproducible test copies: Payara 7 on JDK 21, PostgreSQL 14, a local mail sink, and a synthetic data set from a committed snapshot, in configuration C1 or C2 (`env/up.sh` , `env/reset.sh` , `env/down.sh` ; details in `env/README.md`). Several copies can run side by side. `APP_ENV_AUTH=keycloak` adds a local Keycloak 21.1.2 next to a copy. The copies use test-only settings: default users with default passwords, development data generation, the Europe/Berlin time zone. **These must never reach production.** The environment's own app build skips tests (CI runs them) and needs the Vaadin key by name.

4 Database migration scripts and pre-go-live checks

4.1 No migration script

None is needed. The migration does not change the database schema, so the upgrade needs no migration script beyond what SORMAS v1.104.0 already has. How this was checked:

- The schema files (`sormas-backend/src/main/resources/sql/` , schema version 649) and every other `.sql` file are unchanged between the old and the new code.
- The schema created at start on a fresh database was dumped (`pg_dump -s`) for the old and the new application: identical, with equal object counts.
- Stored JSON text is byte-identical to the old application's.

Two checks on your data are needed before go-live. Both are read-only count queries in `docs/migration/pre-go-live-checks.sql` ; run them with `psql` on the production database (or a copy). Both were run on a test copy of the delivered application; the results are under each check.

4.2 Check 1: rich text that would lose formatting

Counts, per rich text field, the stored texts with formatting the new editor removes on save (section 1.1). `affected_texts` is the number to look at; the other columns say which kind of formatting.

```
WITH texts (field, html) AS (
    SELECT 'action.description', description FROM action
    UNION ALL
    SELECT 'action.reply', reply FROM action
    UNION ALL
    SELECT 'diseaseconfiguration.casedefinitiontext', casedefinitiontext
        FROM diseaseconfiguration
)
SELECT field,
    count(*) FILTER (WHERE html ~* '<font\y') AS font_tags,
    count(*) FILTER (WHERE html ~* '<(table|hr)\y') AS tables_or_rules,
    count(*) FILTER (WHERE html ~* '<h[4-6]\y') AS headings_h4_to_h6,
    count(*) FILTER (WHERE html ~* '<img\y[^>]*\ysrc\s*=\s*(["'']\s*)?(?![\s"'']|data:)')
        AS images_by_address,
    count(*) FILTER (WHERE html ~* 'javascript:|<script\y|<[a-z][^>]*\son[a-z]+\s*=')
        AS scripts_or_event_attributes,
    count(*) FILTER (WHERE html ~* ('<font\y|<(table|hr)\y|<h[4-6]\y'
        || '|<img\y[^>]*\ysrc\s*=\s*(["'']\s*)?(?![\s"'']|data:)'
        || '|javascript:|<script\y|<[a-z][^>]*\son[a-z]+\s*=')) AS affected_texts,
    count(*) AS texts_checked
FROM texts
WHERE html IS NOT NULL AND html <> ''
GROUP BY field
ORDER BY field;
```

The query counts the kinds of formatting the editor's sanitising was shown to remove. Other rare markup outside the editor's allowed list (for example `<center>` or an `align` attribute) also loses its effect and is not counted. **Tested** on a test copy of the delivered application (schema version 649, C1 seed data): 0 rows, because the seed data has no rich text. With 13 synthetic texts added in a transaction that was rolled back (9 with removed formatting, 4 with only kept formatting such as bold, lists, H2 and an embedded image), it counted exactly the 9.

If `affected_texts` is above 0, users will see that formatting disappear the next time they save such a text. Decide whether that matters; if it does, ask for a fix (for example keeping the old formatting when a text is saved unchanged).

4.3 Check 2: records with an empty link

Hibernate 7 loads some required links with an inner join where Hibernate 5 used an outer join. A record with an empty value in one of these six columns would no longer open in the new application (CR03):

```
SELECT 'environments.reportinguser_id' AS column_checked, count(*) AS empty_rows
    FROM environments WHERE reportinguser_id IS NULL
UNION ALL SELECT 'selfreports.address_id', count(*)
    FROM selfreports WHERE address_id IS NULL
UNION ALL SELECT 'eventparticipant.person_id', count(*)
    FROM eventparticipant WHERE person_id IS NULL
UNION ALL SELECT 'campaigns.creatinguser_id', count(*)
    FROM campaigns WHERE creatinguser_id IS NULL
UNION ALL SELECT 'sormastosormassharerequest.origininfo_id', count(*)
    FROM sormastosormassharerequest WHERE origininfo_id IS NULL
UNION ALL SELECT 'sharerequestinfo.sender_id', count(*)
    FROM sharerequestinfo WHERE sender_id IS NULL;
```

Tested on the same copy: 0 in every row. With one participant's person link emptied in a transaction that was rolled back, it showed 1 for `eventparticipant.person_id`.

Expected: 0 in every row. Where a row shows more than 0, fix the data or ask for the mapping of that column to be relaxed before go-live.

5 Licences, third-party code and library advisories

5.1 Licence of the delivered application

SORMAS is licensed under the **GPL v3**, and the migrated code stays under it. The migrated user interface also uses three **Vaadin commercial components**: Rich Text Editor, Charts and Map. They are licensed under the Vaadin Commercial License and Service Terms, not under the GPL. Using them was decided at planning (M0 D8, D10). The `README.md` of the repository opens with this notice. In practice:

- Building the application, or running it in Vaadin development mode, needs a valid Vaadin subscription (section 3.2). Anyone you hand the source to needs their own.
- **Highcharts**, the chart library inside Vaadin Charts, is covered by the Vaadin licence that allows the use of Vaadin Charts, for the Highcharts copy bundled with Vaadin Charts. It does not cover other copies of Highcharts used directly or loaded from elsewhere (confirmed by the licence holder, 2026-11-13). No separate Highcharts licence is needed for the charts as delivered. The old application shipped its own copy of Highcharts 8; that copy is gone.
- Vaadin 25 brings two further parts the application does not use: Collaboration Engine 7.1.0 and the Vaadin AI core components 25.3.5. Both are Apache 2.0 and need no key. They are **excluded** from the UI (`sormas-ui/pom.xml`); remove the exclusion if you later want real-time collaboration or the AI components.

5.2 Third-party code in the migrated code

The migration rewrote the Vaadin 7/8 compatibility layer (navigation, fields, list component, drop-downs and option groups, custom layout) as new SORMAS classes on Vaadin Flow components. A line and block comparison against the Vaadin 8.14.3 and Vaadin 25 sources found no copied blocks of significance: one 11-line block of getter and constructor code follows the Vaadin 8 shape, because the interface had to stay the same; everything else shares only method signatures. **No code under GPL, AGPL, LGPL or Creative Commons share-alike terms was added.**

Third-party material in the delivery: the Open Sans fonts (Apache 2.0, unchanged from Vaadin 8), the Bootstrap grid style sheet (MIT), the htmlwidgets and visNetwork binding JavaScript (MIT, moved unchanged), vis-network from npm (Apache 2.0 or MIT), and the commercial Vaadin Charts, Map and Rich Text Editor components with Highcharts inside. Libraries the old application shipped as files (Leaflet and its plugins, jQuery, vis-network, Highcharts 8) are no longer in the tree. The attributions are in `docs/3RD_PARTY_ACK.md` ; four that were missing were added, and the project's own new files carry the SORMAS GPL v3 header (test code excepted, as before).

5.3 Libraries kept at their old versions, and their advisories

The migration changed only the libraries the new platform forced (Java 21, Jakarta EE 11, Payara 7, Vaadin 25, Hibernate 7). Every other library stays at the old application's version, to keep the change small and the behaviour the same (decision 2026-11-13). A scan of the resolved dependencies against the OSV advisory database (2026-11-13) gives:

	Old application	New application
Shipped libraries	285	342
Known advisories on them	131	128
Critical / high	8 / 49	8 / 49
Moderate / low	63 / 11	60 / 11
Advisories only in this application	3 (Vaadin 8 server, mime4j)	**0**

No advisory is new with the migration; three moderate ones went away with Vaadin 8. The new platform parts (Vaadin 25, Hibernate 7, Jakarta, Jersey, Ehcache 3) have no advisory today. The critical and high ones sit in these kept libraries (each advisory counted once per library):

Library (version kept)	Critical / high	Note
HAPI FHIR `org.hl7.fhir.utilities` 6.0.1, `org.hl7.fhir.r4` 6.0.21	2 / 6	XML external entities, FHIRPath; used for audit logging, which parses no outside XML (probably not reachable, not tested)
Netty 4.1.95 (handler, codecs)	1 / 16	Client side only (through etcd/gRPC); the application runs no Netty server
Bouncy Castle `bcprov-jdk18on` 1.76	2 / 2	
Apache Tika 2.8.0 (core, PDF module)	2 / 0	XML external entities in crafted PDFs: **reachable** by users who may upload documents
PostgreSQL driver 42.6.0	1 / 1	
Jackson 2.13.4 (databind, core)	0 / 8	Held at 2.13.4 by the REST and persistence integrations
Keycloak libraries 21.1.2	0 / 4	Mostly about a Keycloak server, not these client libraries
Spring 5.3.27, logback 1.3.5, guava 32.0.1, commons-io 2.13.0, commons-beanutils 1.9.4, jsoup 1.16.1, protobuf 3.21.7, docx4j 8.3.9, junrar 7.5.4, iText 2.1.7	0 / 1 to 2 each	

Limits of the scan: OSV by library coordinates only; Payara's own libraries are not covered; advisory databases change daily, so re-run the scan before each release.

5.4 Proposed upgrades: a follow-up offer

Upgrading these libraries is outside a minimal-change migration, but it is the natural next question. We propose two tiers and can do them as a follow-up:

1. **Low-risk minor upgrades**, one change with the full workflow suite as the test: PostgreSQL driver 42.7.x, Netty 4.1.137, Bouncy Castle 1.85, the latest Jackson 2.x the REST stack supports, logback, guava, commons-io, jsoup.
2. **Major-version upgrades**, one by one, each with its own risks: Tika 2 to 3 first (the reachable critical advisory), HAPI FHIR 6.0 to 6.9 or later (audit logging), the Keycloak libraries 21 to 26 (together with the Keycloak server version), Spring 5 to 6, iText 2.1.7 and docx4j.

We also suggest running the advisory scan in CI so the number is tracked.

6 Known pre-existing issues

These problems exist in the old application too. The migration keeps them, so that the new application behaves like the old one; fixing them is a separate decision. The Ref. column is the migration's reference number.

6.1 To act on

Ref.	Problem	What to know
B065	Date-and-time fields (event start, sample collection, task, visit, treatment): a mistyped date part saves the record with the date-time empty, losing the previous value	Data loss. **To be fixed right after the migration** (decision 2026-11-12); a one-line fix exists
B050	Case import template: the template says dates are `dd/MM/yyyy` but they are read as `M/D/YYYY` (05/11/2026 is imported as 11 May 2026)	Silent wrong dates on import; tell users or fix the template
B045	A disease variant created for "All diseases" and used on a case breaks the case directory ("An unexpected error occurred")	Avoid such variants, or fix
B007	Survey question and answer texts from outside data are shown as HTML without escaping (stored script injection)	Security; fix after the migration
B008	Error messages, which can contain user input, are shown as HTML without escaping	Security; fix after the migration
B060, B061	`/metrics` answers without login; no Content-Security-Policy, no HSTS, session cookie without `Secure` / `SameSite`	Close `/metrics` on public listeners; add the headers and cookie flags behind TLS
B018	The REST catch-all error answer contains the exception message	Information disclosure
B056	Chart options are built by joining captions and region or campaign names into script code: a quote in a name breaks the chart and could inject script	Security (minor); fix after the migration
B006	Payara 5, free Vaadin 8 and Hibernate 5.6 were out of maintenance (resolved by the migration); PostgreSQL 14 support ended 2026-11-12	Plan the database server upgrade

6.2 Errors users may see

Ref.	Where	Problem
B025	Case therapy and port health pages (some users)	Error notification on opening
B026	Travel entry pages, C2 (administrator, lab officer, hospital informant)	Error notification on opening
B027	Sample page and person page with a tested sample, hospital informants and other facility users	"Facility is not supported for environment samples"
B038	Surveillance dashboard map, "Hide other countries"	"An error has occurred"; the same code path is kept (checked by reading the code, not re-run)
B046	Hospital informant choosing a disease for a new case	Fixed by the migration (section 1.4)
B054, B055	Participants of an archived event; pathogen test form when switching from Shigellosis	Error (found by reading code, not reproduced)
B057	Travel entry create after the similar-persons warning	The dialog reopens titled "Create new immunization"
B064	Event directory for jurisdiction users	Duplicates and missing events. Fixed by the migration (section 1.5)

6.3 Display and wording

- Successful saves of epidemiological and person data show a warning-styled "Warning: ... saved" (B029).
- The line listing window shows dates as M/D/YY (B031); later lines' inputs have no accessible names (B033).
- The case directory does not keep its sort order after navigating away and back (B032).
- Under German: untranslated or mixed captions, raw vaccine constants, a "?" in the AEFI header, "EXTERNALRESPONDENTID", M/D/YY on the dashboard custom period (B035, B036, B041, B042, B044).
- The case created from a COVID-19 travel entry has no disease (B034); a case from a self report shows "Case reference number: null" (B043).
- The samples dashboard counters read 0 after a period change until "Apply filters" (B037).
- Count labels show 0 on the areas and disease configuration lists (B063).
- After a merge the view still reads "1 potential duplicates detected" (B049).
- The quarantine order window stays open after the download (B051).
- A hospital informant's preset facility shows "(Inactive)" although it is active (B052).
- Reopening an exposure of type "Other" shows the activity details empty and required although stored (B048).
- The bulk progress window can show 0/N for several seconds (B030).

6.4 Operations and tests

- About 37 SEVERE log lines from annotation scanning at each deploy (B002), a Log4j2 "could not find a logging implementation" line on each data dictionary export (B040), and Vaadin event-router warnings on dashboards (B047): log noise only.
- Hibernate schema validation would fail on one AEFI column (text against an integer mapping) in old and new alike; validation is off (B062).
- One backend test fails when it runs between 00:00 and 06:00 in the build machine's time zone (B059); it is on the list for right after the migration (CR39). Another fails rarely when a random id contains "555" (B066). One test needs the git `origin` to be a URL (B003). The Testcontainers test is skipped silently without the Docker API version setting (B004; CI enforces it).
- Every event save also refreshes all its participants (change date, vaccination status, one history row) because of how the old date-time field worked; this is kept on purpose and could be cleaned up later.

7 Behaviour changes and their decisions

"M0 D1" to "M0 D10" and "M0 P10a" to "P10c" are the numbers of the questions answered at the planning milestone (M0); "option A, B, C, K" are the answers chosen on the decision pages. The internal reviewer answered as the customer's representative.

7.1 Decided at planning and during the migration

Change	Decision	By, when
Old `#!` links open the start page; no redirect	Accepted	Customer, 2026-11-05
Task e-mail links use the new address format	Accepted (M0 D5)	Customer, 2026-11-06
Unknown or forbidden sub-pages show "not found"/"access denied" instead of the parent page	Accepted (M0 D4)	Customer, 2026-11-06
Survey-window and error-message HTML (B007, B008) kept as before	Kept for parity, fix later (M0 D1)	Customer, 2026-11-06
Commercial components: Rich Text Editor, Charts, Map; licence notice in the README	Accepted (M0 D8, D10)	Customer, 2026-11-06
Node.js and npm downloads for frontend builds	Allowed (M0 D9)	Customer, 2026-11-06
Stored JSON stays byte-identical	Decided (M0 P10a)	Customer, 2026-11-06
EJB pool 128 as SORMAS intends; fall back to 32 with a note if it cannot be set	Decided (M0 P10b). It was set; the setup script now warns if it is not	Customer, 2026-11-06
Notifications keep the Vaadin 8 timing where possible	Decided (M0 P10c). Kept; no notification type needed the exception	Customer, 2026-11-06
Web login check in the application instead of the server constraint	Accepted (option B)	Customer, 2026-11-06
CI builds with the commercial banner instead of a CI key	Accepted (option C)	Customer, 2026-11-07
Global theme settings (palette, font, sizes, menu)	Accepted (option A)	Customer, 2026-11-12
Map differences (hover names, marker spreading, clusters, square markers, finer zoom, world zoom); chart export menu kept, with the export server note	Accepted (A, A, K)	Customer, 2026-11-12
Date-and-time fields losing a mistyped value (B065)	Kept now, fixed right after the migration	Customer, 2026-11-12
Next user after a logout lands on the previous user's last page	Kept as in the old application	Migration team 2026-11-08; confirmed by customer 2026-11-12
Code-set values that are not among a drop-down's options are ignored	Kept as in the old application	Migration team 2026-11-08; confirmed 2026-11-12
Refused Save lists fields in form order	Improvement accepted	Migration team 2026-11-08; confirmed 2026-11-12
Hospital informant person-page error (B027)	Kept as in the old application; fix offered after the migration	Migration team 2026-11-08; confirmed 2026-11-12

Change	Decision	By, when
Highcharts covered by the Vaadin Charts licence for the bundled copy	Confirmed	Licence holder, 2026-11-13
Libraries not forced by the platform stay at the old versions; advisories and an upgrade offer in the hand-off	Decided	Customer, 2026-11-13

7.2 Change review (answered 2026-11-13)

The changes that earlier checkpoints had deferred were put to the internal reviewer as 43 items (CR01 to CR43), each with a suggestion. All 43 were answered on 2026-11-13: five explicitly, the other 38 as suggested.

Answer	Items
Accepted as they are	CR01, CR05 to CR10, CR12, CR14, CR19, CR21, CR22, CR25 to CR28, CR30 to CR33, CR40 to CR43 (described in section 1 or 2)
Accepted as a **material functional change**, with a count before go-live	CR02 rich text (sections 1.1 and 4.2)
Check your database before go-live	CR03 six columns (section 4.3)
Accepted with a note in this document	CR13 REST rights edited in the database (2.4); CR16 security gaps kept (2.4, 6); CR17 page size, measure later if needed (2.8); CR23 calendar button translations (9); CR34 Payara transport setting (3.3); CR37 server answers (2.7); CR38 memory and sessions, watch in the pilot (2.8)
Fixed: restored to the old behaviour	CR04 two-digit years; CR18 notification close icon; CR20 read-only values as text; CR24 sort arrow only on the sorted column; CR29 browser warning before leaving unsaved changes (sections 1.2, 1.3)
Fixed: hardening	CR15 login target must be a page of the application (1.3)
Done: checked	CR11 Keycloak tested against a local Keycloak (2.5); CR35 two unused Vaadin parts excluded (5.1); CR36 advisory scan (5.3)
After the migration	CR39 the backend test that fails between 00:00 and 06:00 (B059), with the B065 fix (9)

7.3 Improvements beyond parity

Improvement	Decision
Event directory lists distinct events (B064 fixed)	Old defect not copied; register
Statistics picks recognised by identity, not position (B058)	Old defect not copied; register
Self report export no longer writes component object text	Register; accepted CR06
Hospital informants: no error on choosing a disease (B046)	Register; accepted CR01
Two-part read-only fields no longer raise an error	Register; accepted CR10
Refused-Save field list in form order	Confirmed 2026-11-12
User roles export in a fixed order	Register; accepted CR07
Rich text: scripts and event attributes removed	M0 D10
Charts: keyboard navigation and screen-reader descriptions	Register
Browser warning before reload or tab close with unsaved changes	Decided 2026-11-13

7.4 To be confirmed

Two side effects of restoring the old two-digit-year rule (CR04) go beyond parity. They are recorded as improvements and wait for the customer's confirmation **[TO CONFIRM: accept both as improvements]**:

1. **Birth date filters** of the person, case and contact directories, and some other date fields (pathogen test report date, quick immunization dates, customizable date fields), read a typed `1/1/45` as the year **0045** in the old application. The new application reads 1945 there too, as in the forms.
2. **The year 00:** the old forms read `3/14/00` as **2001** (an old quirk). The new application reads 2000.

8 How to run and test

8.1 Build

```
# JDK 21, Maven 3.9, a Vaadin key in ~/.vaadin/proKey or VAADIN_PRO_KEY
cd sormas-base
mvn clean install                  # all modules and all unit tests
mvn clean install -DskipTests      # without tests
```

The build compiles the backend EAR (`sormas-ear`), the REST and UI wars, the server libraries and the Keycloak password hash provider. The Android app profile is not part of it.

Unit tests need a running Docker for the Testcontainers test. With Docker 29 or later, set `api.version=1.44` in `~/.docker-java.properties` (see `CI.md`). One test reads the repository's git `origin` and fails when it is a local path.

8.2 Start a test copy

```
env/up.sh                          # builds, starts C1: http://localhost:18080/sormas-ui/
APP_ENV_CONFIG=C2 APP_ENV_PORT=18081 APP_ENV_PROJECT=sormas-new-c2 env/up.sh --no-build
env/reset.sh                       # back to the seed data
env/down.sh                        # remove the copy
```

Test users are the application's default users (`admin` , `SurvSup` , `NatUser` , `SurvOff` , `LabOff` , `HospInf` , `PoeSup` , `NatClin` ; in C2 also `CfgUser`). Their passwords are the built-in defaults in `sormas-api/.../DefaultEntityHelper.java` , for test copies only. `APP_ENV_PWCHECK=on` shows the default-password alert. `APP_ENV_MODE=dev` starts Vaadin development mode, for checks only. `APP_ENV_AUTH=keycloak` adds a local Keycloak.

8.3 Unit tests

Module	Old application	New application
`sormas-api`	200	200
`sormas-backend`	1,730 (7 skipped)	1,740 (7 skipped)
`sormas-keycloak-service-provider`	none	5
`sormas-rest`	2	2
`sormas-ui`	136 (4 skipped)	285 (4 skipped)
Total	**2,068, 11 skipped**	**2,232, 0 failed, 11 skipped**

The 11 skipped tests are the same in both: they were already disabled in the old code. The migration added 164 tests and disabled, skipped, removed or commented out none.

8.4 End-to-end workflow tests

The module `sormas-e2e-playwright` (Playwright for Java and JUnit 5) holds all 62 workflows of the migration's catalogue as browser tests: one test class per workflow, one ordered test per step (288 steps), with the workflow's data checks as SQL in the last step. Each class gets a freshly reset app copy started with `env/` . After every step the

test also fails on any browser console error or HTTP error. The module is off the default build.

```
env/build.sh                                              # once, and after app changes
mvn -f sormas-e2e-playwright/pom.xml verify               # all workflows, 2 app copies
mvn -f sormas-e2e-playwright/pom.xml verify -De2e.ports=18720-18724   # 5 copies at once
mvn -f sormas-e2e-playwright/pom.xml verify -Dit.test='WF03*'         # one workflow
```

Each copy needs about 3 GB of memory. All 62 workflows took about 15 minutes with five copies on a 10-CPU machine (11 runs in a row, all clean after the last fix), and about an hour in CI with three copies. The module's `README.md` explains settings, how it works and how to add a workflow.

The Keycloak login test `KeycloakLoginIT` is opt-in, because it needs a Keycloak copy (about 3 minutes):

```
mvn -f sormas-e2e-playwright/pom.xml verify -De2e.excludedGroups=none \
    -Dit.test=KeycloakLoginIT -De2e.ports=18730
```

The older Selenium/Cucumber suite `sormas-e2e-tests` was left as it is. It was written for the old user interface and was neither run nor updated in the migration.

9 Follow-up candidates

The migration kept a list of improvements it was not allowed to make, because they go beyond parity. These are the most valuable for a follow-up:

1. **Fix B065** (date-and-time fields losing a value) and the backend test that fails between 00:00 and 06:00 (B059): agreed for right after the migration.
2. **Library upgrades** in two tiers (section 5.4), with the advisory scan in CI.
3. **Security hardening:** close `/metrics` on public listeners; add Content-Security-Policy, HSTS and `Secure` / `SameSite` cookies behind TLS; escape the survey and error-message HTML (B007, B008); invalidate the session after a refused login and rotate the session id at login.
4. **Report two Payara 7 defects upstream** (role checks fail after a remote EJB call; the root-address permission). Reproducers and issue drafts exist. Once Payara fixes them, the server-side role checks can return.
5. **Translations** of the new date-picker "Today" and "Cancel" buttons for the 53 languages other than English and German.
6. **Page size:** first responses are 4 to 12 times larger than before. Measure on a slow link; reducing them (fewer client calls per form) would help.
7. **Look items:** hover names on map regions; the responsive (collapsing) menu under 1100 px; captions cut with an ellipsis in filter rows; the side panel moving under the form on narrow screens; notification details (caption size, error position, warning colours).
8. **Lenient date input:** accept extra date spellings in date fields, as the old date field did.
9. **CI:** a faster end-to-end job (a measured option cuts it from about 61 to 33 minutes, two failures to resolve first); shorten the backend tests; add a concurrency group; pin image and action versions.
10. **Logout:** send the browser to the plain login page after a logout, so the next user lands on their own start page (one line).
11. **Setup and Keycloak material:** the small gaps listed in sections 2.5 and 3.3.
12. **Clean-ups:** a deprecated `glassfish-web.xml` (move to `payara-web.xml`), Vaadin and Hibernate APIs deprecated for removal, unused Valo theme files, and the README's upstream CI badge.

10 Side-by-side recordings

A side-by-side walkthrough of every workflow, old and new application, comes with the final hand-off. It is built from a same-day run of both applications on the final code. It is not part of this version **[TO CONFIRM: delivered with the final hand-off]** .

Appendix A. Open points

- Customer acceptance (milestone M3) is not reached. The internal reviewer's own test run before M3 is not done yet.
- The two-digit-year improvements in section 7.4 wait for confirmation.
- The side-by-side walkthrough export comes with the final hand-off (section 10).
- An upgrade on a copy of production data has not been rehearsed (section 3.4).
- Where the migrated code ends up (`main` or the `mig-dev` branch) is undecided.
- Whether the library upgrades and other follow-ups are ordered (sections 5.4 and 9).